بِسْمِ اللّٰهِ الرَّحْمٰنِ الرَّحِيْمِ

اَلْحَمْدُ لِلّٰهِ رَبِّ الْعَالَمِيْنَ

وَالصَّلٰوةُ وَالسَّلَامُ عَلٰى خَاتَمِ النَّبِيِّيْنَ

# Chapter 8
# Intrusion Detection

# Definitions

- Security Intrusion:

  **Unauthorized act of bypassing the security mechanisms of a system**

- Intrusion Detection:

A hardware or software function that **gathers and analyzes information** from various areas within a computer or a network to identify possible security intrusions

# Examples of Intrusion

- Remote root compromise
- Web server defacement
- Guessing/cracking passwords
- Copying databases containing credit card numbers
- Viewing sensitive data without authorization
- Running a packet sniffer
- Distributing pirated software
- Using an unsecured modem to access internal network
- Impersonating an executive to get information
- Using an unattended workstation

# Intrusion Patterns

- Modification of system resources
- Privilege-escalation exploits
- Buffer-overflow exploits
- Access to e-mail contact list
- Directory traversal

# Intruder Behavior

**Target acquisition and information gathering**

**Initial access**

**Privilege escalation**

**Information gathering or system exploit**

**Maintaining access**

**Covering tracks**

# Intruder Behavior Examples

**(a) Target Acquisition and Information Gathering**

- Gather information on target network using tools such as NSLOOKUP, and WHOIS database.
- Map network for accessible services using tools such as NMAP.
- Send query emails to customer service to review response for mail client, server, and OS used

**(b) Initial Access**

- Brute force (guess) a user's **web content management system (CMS)** password.
- Exploit vulnerability in web CMS plugin to gain system access.
- Send spear-phishing email with link to web browser exploit to key people.

**(c) Privilege Escalation**

- Scan system for applications with local exploit.
- Exploit any vulnerable application to gain elevated privileges.
- Install sniffers to capture administrator passwords.
- Use captured administrator password to access privileged information.

# Intruder Behavior Examples

**(d) Information Gathering or System Exploit**

- Scan files for desired information.
- Transfer large numbers of documents to external repository.
- Use guessed or captured passwords to access other servers on network.

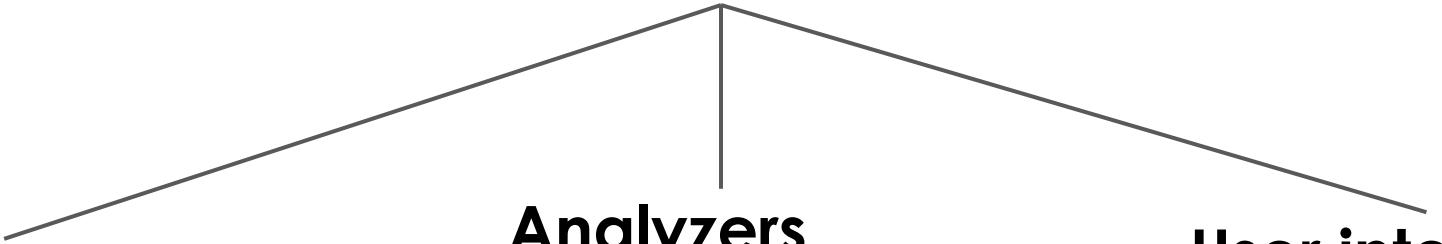
**(e) Maintaining Access**

- Install remote administration tool or rootkit with backdoor for later access.
- Use administrator password to later access network.
- Modify or disable anti-virus or IDS programs running on system.

**(f) Covering Tracks**

- Use rootkit to hide files installed on system.
- Edit logfiles to remove entries generated during the intrusion

# IDS logical components



**Sensors**
collect data

**Analyzers**
determine if intrusion has occurred

**User interface**
view output or control system behavior

# IDS: Analysis Approaches

**Models normal behaviour**

## Anomaly

**Knowledge based**: a set of rules that model legitimate behavior
**Statistical**: Probabilistic models of observed metrics
**Machine-learning**: parametric model optimized from the training data

***Input metrics e.g.***: *System behaviour* e.g files modification, registry access or *traffic features* e.g. Average packet size, Number of packets per flow, Bytes per second, Packet inter-arrival time mean and variance, TCP flags count (e.g. SYN, ACK ratios)

**Model abnormal behaviour (intrusion)**

## Signature

**A recognizable pattern of an attack stored in database**
e.g.

- A specific sequence of bytes (a hacker's known flag message)
- A pattern of system calls made by a malware

## Heuristic

**suspicious behavior patterns**: might not belong to a known attack: e.g
If a user tries to log in more than 5 times within 1 minute and fails each time
If a device suddenly sends 1000 MB of data outside the network

# Analysis Approaches

## Anomaly detection

- Involves the **collection of data relating to the behavior of legitimate users** over a period of time
- Current observed behavior is analyzed to d**etermine whether this behavior is that of a legitimate user or that of an intruder**

## Signature/Heuristic detection

- **Uses a set of known malicious data patterns or attack rules** that are compared with current behavior as in antivirus
- Also known as misuse detection
- **Can only identify known attacks** for which it has patterns or rules

# Anomaly Detection

A variety of classification approaches are used:

| Statistical | Knowledge based | Machine-learning |
| --- | --- | --- |
| • Analysis of the observed behavior using univariate, multivariate, or time-series models of observed metrics | • Approaches use an expert system that classifies observed behavior according to a set of rules that model legitimate behavior | • Approaches automatically determine a suitable classification model from the training data using data mining techniques |

# Signature Detection

## Signature approaches

**Match a large collection of known patterns of malicious data against data stored on a system or in transit over a network**

**The signatures need to be large enough to minimize the false alarm rate, while still detecting a sufficiently large fraction of malicious data**

**Widely used in anti-virus products, network traffic scanning proxies, and in NIDS**

**Signature**:
A recognizable pattern of an attack e.g.
A specific sequence of bytes (a hacker's known flag message)
A pattern of system calls made by a malware

# Heuristic Detection

**Heuristic rules** based on **suspicious behavior patterns**: might not belong to a known attack: e.g

If a user tries to log in more than 5 times within 1 minute and fails each time

If a device suddenly sends 1000 MB of data outside the network

## Rule-based heuristic identification

**Involves the use of rules for identifying known penetrations or penetrations that would exploit known weaknesses**

**Rules can also be defined that identify suspicious behavior, even when the behavior is within the bounds of established patterns of usage**

**Typically rules used are specific**

**SNORT is an example of a rule-based NIDS**

# IDS placement (sensors)

## Host-based IDS (HIDS)

Monitors characteristics of a single host. Data sources include:

- **System call traces**
- **Audit (log file) records**
- **File integrity checksums**
- **Registry access**

## Network-based IDS (NIDS)

Monitors traffic at **selected network points** and examines the traffic in real or close to **real time** analyzing network, transport, and application layer **protocol and traffic parameters**

## Distributed or hybrid IDS

**Combines** information from a number of sensors, on both host and network based sensors, in a central analyzer

# Intrusion Detection System (IDS)

- **Host-based IDS (HIDS)**
  - Monitors the characteristics of a single host for suspicious activity
- **Network-based IDS (NIDS)**
  - Monitors network traffic and analyzes network, transport, and application protocols to identify suspicious activity
- **Distributed or hybrid IDS**
  - Combines information from a number of sensors, often both host and network based, in a central analyzer that is able to better identify and respond to intrusion activity

**Comprises three logical components:**

- **Sensors -** collect data
- **Analyzers -** determine if intrusion has occurred
- **User interface -** view output or control system behavior

# Host-Based Intrusion Detection (HIDS)

- Adds a specialized layer of security **software to vulnerable or sensitive systems**
- Can use either anomaly or signature and heuristic approaches
- Monitors activity to detect suspicious behavior
  - Primary purpose is to detect intrusions, log suspicious events, and send alerts
  - Can detect both external and internal intrusions

# HIDS: Data Sources and Sensors

A fundamental component of intrusion detection is the sensor that collects data

Common data sources include:

- **System call traces**
- **Audit (log file) records**
- **File integrity checksums**
- **Registry access**

# HIDS: Sensors

• **System call traces**: While these work well on Unix and Linux systems, they are problematic on Windows systems due to the extensive use of DLLs that obscure which processes use specific system calls.

• **Audit (log file) records:** The advantage of using this information is that no additional collection software is needed. The disadvantages are that the audit records may not contain the needed information or may not contain it in a convenient form, and that intruders may attempt to manipulate these records to hide their actions.

• **File integrity checksums**: A common approach to detecting intruder activity on a system is to periodically scan critical files for changes from the desired baseline, by comparing a current cryptographic checksums for these files, with a record of known good values. Disadvantages include the need to generate and protect the checksums using known good files, and the difficulty monitoring changing files. **Tripwire** is a well-known system using this approach.

• **Registry access**: An approach used on Windows systems is to monitor access to the registry, given the amount of information and access to it used by programs on these systems. However this source is very Windows specific, and has recorded limited success.

# Network-Based IDS (NIDS)

Monitors traffic at selected points on a network

Examines traffic packet by packet in real or close to real time

May examine network, transport, and/or application-level protocol activity

Comprised of a number of sensors, one or more servers for NIDS management functions, and one or more management consoles for the human interface

Analysis of traffic patterns may be done at the sensor, the management server or a combination of the two

# NIDS: Intrusion Detection Techniques

## Signature detection

- Application layer attacks
- Transport layer attacks
- Network layer attacks
- Policy violations

## Anomaly detection

- Denial-of-service (DoS) attacks
- Scanning
- Worms

# NIDS signature detection

- **Application layer attacks:** analyze several dozen application protocols. E.G. DHCP, DNS, IMAP, SIP, SMTP, SNMP, Telnet, and TFTP Looking for attack patterns that have been identified as targeting these protocols e.g. password guessing, and malware transmission.

- **Transport layer attacks:** analyze TCP and UDP traffic for unusual packet fragmentation, scans for vulnerable ports, and TCP-specific attacks such as SYN floods.

- **Network layer attacks:** analyze IPv4, IPv6, ICMP, and IGMP for spoofed IP addresses (e.g strange TTL/IP values) and illegal IP header values.

- **Policy violations:** looking for use of inappropriate Web sites and use of forbidden application protocols

# NIDS Anomaly detection

• **Denial-of-service (DoS)**: Anomaly detection is well suited to such attacks as they involve either significantly increased packet traffic or significantly increase connection attempts

• **Scanning**: A scanning attack occurs when an attacker probes a target network or system by sending different kinds of packets. Scanning can be detected by atypical flow patterns at the application layer (e.g., banner grabbing as by HEAD / HTTP/1.0), transport layer (e.g., TCP and UDP port scanning), and network layer (e.g., ICMP scanning).

• **Worms**: Worms can be detected because they can cause hosts to communicate with each other that typically do not, and they can also cause hosts to use ports that they normally do not use. Many worms also perform scanning.

# Logging of Alerts

Typical information logged by a NIDS sensor includes:

- Timestamp
- Connection or session ID
- Event or alert type
- Rating
- Network, transport, and application layer protocols
- Source and destination IP addresses
- Source and destination TCP or UDP ports, or ICMP types and codes
- Number of bytes  transmitted over the connection
- Decoded payload data, such as application requests and responses
- State-related information

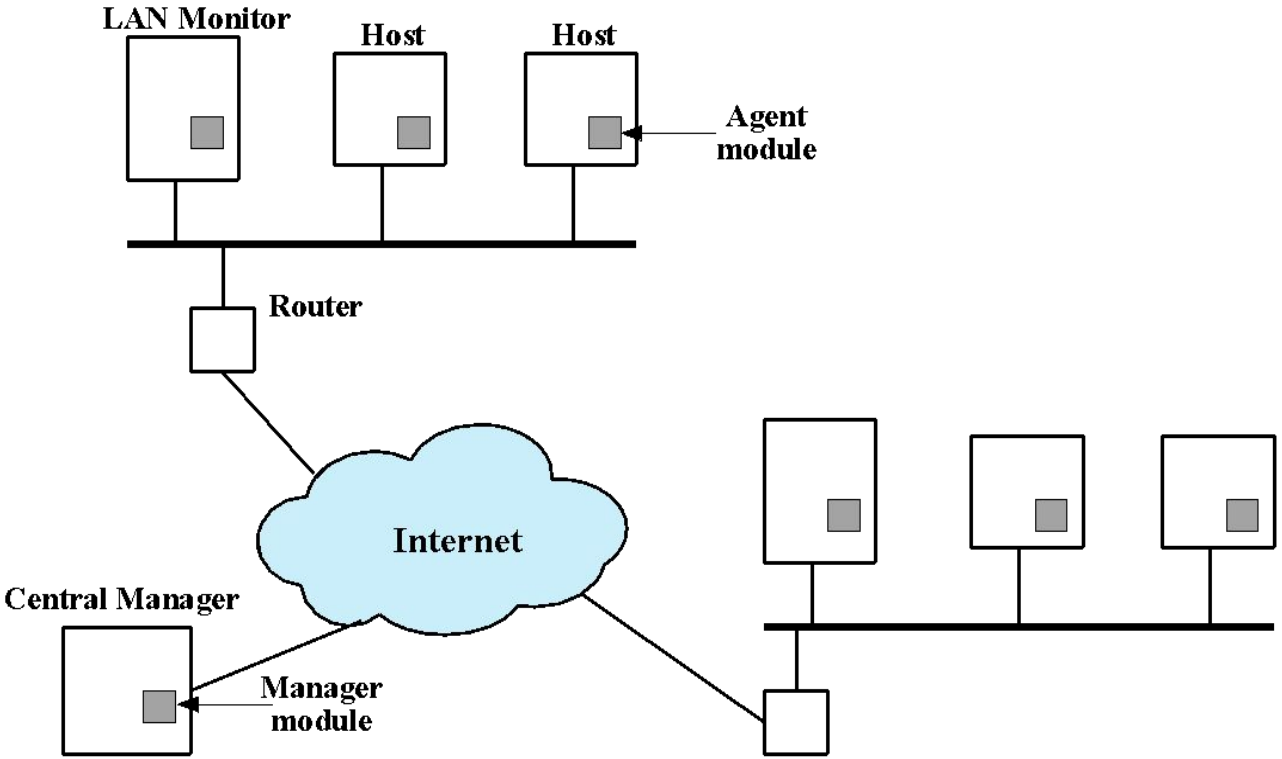



Figure 8.2 Architecture for Distributed Intrusion Detection

# Distributed or hybrid IDS:

Combines information from a number of sensors, on both host and network based sensors, in a central analyzer that is able to better identify and respond to intrusion activity

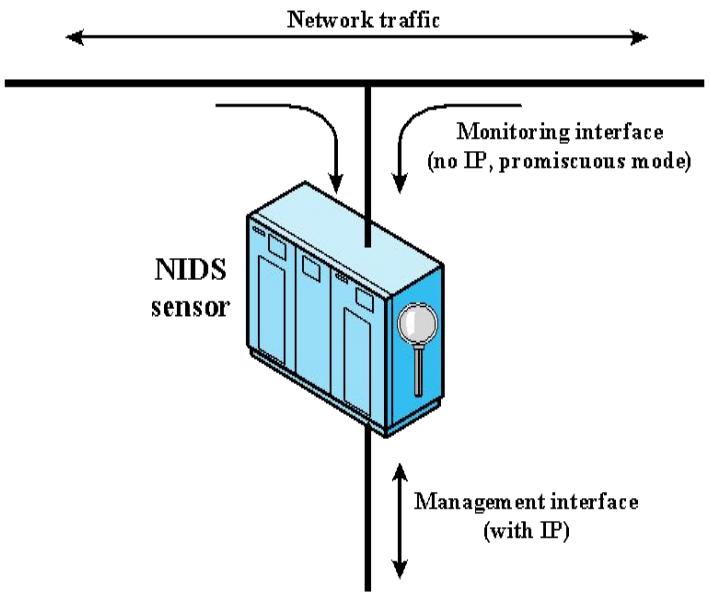



Figure 8.4 Passive NIDS Sensor

A **passive sensor** monitors a copy of network traffic; the actual traffic does not pass through the device. From the point of view of traffic flow, the passive sensor is more efficient than the inline sensor, because it does not add an extra handling step that contributes to packet delay.

An **inline sensor** is inserted into a network segment so that the traffic that it is monitoring must pass through the sensor. E.g. by combining NIDS sensor logic with a **firewall**. An alternative is a stand-alone inline NIDS sensor.
The primary motivation for the use of inline sensors is to enable them to **block** an attack when one is detected performing both intrusion detection and **intrusion prevention IPS** functions.

## Intrusion Prevention System IPS:

When a flow is determined to be malicious, the latest and all subsequent packets belonging to the suspect flow are dropped.

# Honeypots

- **Decoy systems** designed to:
  - **Lure a potential attacker away** from critical systems
  - **Collect information about the attacker's** activity
  - **Encourage the attacker to stay on the system long enough for administrators to respond**
- Systems are **filled with fabricated information** that a legitimate user of the system wouldn't access
- Resources that have no production value
  - Therefore incoming communication is most likely a probe, scan, or attack
  - Initiated outbound communication suggests that the system has probably been compromised

# Honeypot Classifications

- Low interaction honeypot (e.g. Honeyd)
  - Consists of a **software package that emulates particular IT services or systems** well enough to provide a realistic initial interaction, but does not execute a full version of those services or systems
  - Provides a less realistic target
  - Often sufficient for use as a component of a distributed IDS to warn of imminent attack
- High interaction honeypot
  - **A real system, with a full operating system**, services and applications, which are instrumented and deployed where they can be accessed by attackers
  - Is a more realistic target that may occupy an attacker for an extended period
  - However, it requires significantly more resources
  - If compromised could be used to initiate attacks on other systems

# Activity

1. Complete the following tryhackme room

https://tryhackme.com/room/snort

2. Search, install and explore configuration of following tools:

- Honeyd
- Snort